

AUTH_SIMPLE_MODE — Sistema de Autenticación Simplificado

Introducción

Hammer POS/ERP usa un sistema de autenticación **basado en usuario y contraseña** con cookies firmadas (HMAC-SHA256). Este documento describe cómo funciona el flujo completo, desde el primer login hasta la gestión de usuarios.

Resumen del Flujo

1. Seed/Bootstrap → Crea usuario MASTER
 2. Login → Usuario ingresa credenciales
 3. Backend → Valida, genera cookie firmada
 4. mustChangePassword? → Redirige a /app/change-password
 5. Usuario cambia contraseña → Sesión revocada
 6. Re-login con nueva contraseña → Acceso completo

Credenciales por Defecto

Desarrollo (seed.ts)

Campo	Valor
Usuario	master
Contraseña	ElChele1234!
Rol	MASTER

Producción (seed-production.ts)

Variable de entorno	Obligatorio	Descripción
MASTER_INITIAL_USERNAME	No	Default: master
MASTER_INITIAL_PASSWORD	Sí	Debe cumplir política de seguridad

 En producción, `MASTER_INITIAL_PASSWORD` es **obligatoria** y debe tener: min 10 caracteres, mayúscula, minúscula, número y símbolo.

Cómo Funciona el Primer Login

IMPORTANTE: TODOS los usuarios (incluido MASTER) deben cambiar la contraseña inicial en su primer login.

1. **Se ejecuta el seed** → Se crea el usuario MASTER con contraseña `ElChele1234!` y `mustChangePassword: true`
2. **El MASTER hace su primer login** → Es redirigido a `/app/change-password` para cambiar la contraseña inicial
3. **El MASTER cambia su contraseña** → Se marca `mustChangePassword: false`, sesiones revocadas
4. **El MASTER crea un nuevo usuario** → El usuario se crea automáticamente con contraseña `ElChele1234!` y `mustChangePassword: true`
5. **El nuevo usuario hace login** → El backend detecta `mustChangePassword: true` y retorna `redirectTo: "/app/change-password"`
6. **El usuario cambia su contraseña** → Se marca `mustChangePassword: false`, sesiones revocadas
7. **Re-login** → El usuario inicia sesión con su nueva contraseña y accede normalmente

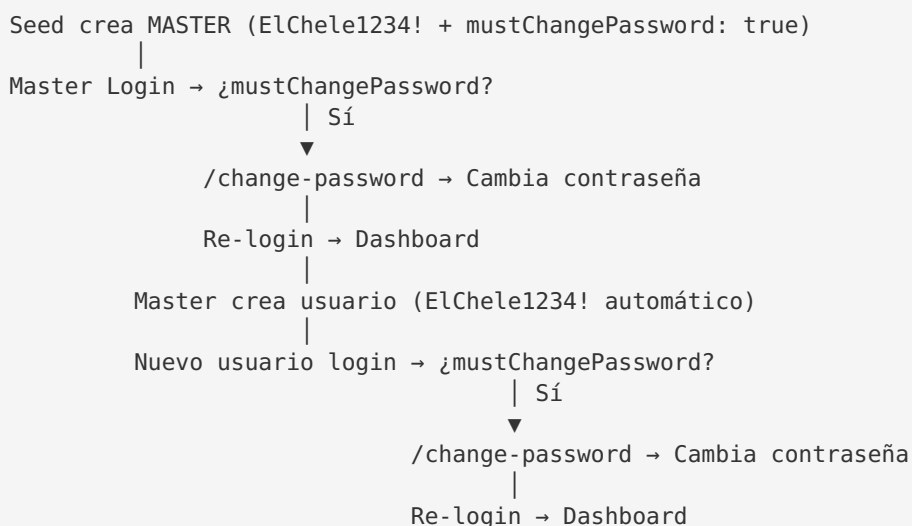
Contraseña Universal

La contraseña `ElChele1234!` se usa como contraseña inicial universal para:

- ☒ Usuarios MASTER creados por seed
- ☒ Usuarios nuevos creados desde el panel master
- ☒ Resets de contraseña (tanto desde panel como por script)

Nunca se generan contraseñas aleatorias. Esto simplifica la comunicación con los empleados.

Flujo visual



Cómo Crear Usuarios

Desde el Panel Master (/app/master/users)

1. Navegar a **Usuarios** en el menú master
2. Llenar el formulario:
 - **Usuario**: nombre único (ej: `juan.mga`)
 - **Nombre completo**: nombre real del empleado
 - **Correo**: opcional (se auto-genera `usuario@hammer.local` si está vacío)
 - **Rol global**: `MASTER` o vacío (sin rol global)
3. Clic en **“Crear usuario”**
4. La contraseña se asigna **automáticamente** como `ElChele1234!` (no se puede personalizar)
5. El usuario tendrá `mustChangePassword: true`
6. Informar al empleado: “Tu contraseña es ElChele1234!, cámbiala al hacer login”
7. En su primer login, será obligado a cambiar la contraseña

Asignar Sucursal/Rol

Después de crear el usuario:

1. Seleccionarlo en la lista
2. En **“Asignar membresía”**, elegir sucursal y rol:
 - `BRANCH_ADMIN` — Administrador de sucursal
 - `SALES` — Ventas / POS
 - `CASHIER` — Caja
 - `WAREHOUSE` — Bodega
3. Clic en **“Asignar membresía”**

Cómo Resetear Contraseñas

Desde el Panel Master

1. Seleccionar el usuario en la lista
2. Usar el botón **“Resetear Contraseña a ElChele1234!”**
3. Se muestra un modal de confirmación con la contraseña `ElChele1234!`
4. **Copiar la contraseña** con el botón de copiar
5. Confirmar el reset
6. Informar al empleado que su nueva contraseña es `ElChele1234!`
7. El usuario deberá cambiarla en su siguiente login (`mustChangePassword: true`)

Nota: No se generan contraseñas aleatorias. Siempre se restablece a `ElChele1234!` .

Resetear Contraseña del Master (CLI)

```
# Desarrollo – restablece a ElChele1234!
cd hammer-api
npm run auth:reset-master

# Producción – restablece a ElChele1234! con mustChangePassword: true
npx tsx scripts/reset-master-password.ts

# 0 vía seed con reset
MASTER_INITIAL_PASSWORD="ElChele1234!" RESET_MASTER_PASSWORD=true npm run db:seed:prod
```

Variables de Entorno

hammer-api/.env

```
# Requerido – conexión a base de datos
DATABASE_URL="postgresql://..."

# Requerido – secreto para firmar cookies de sesión (mín 32 chars)
AUTH_SESSION_SECRET="tu-secreto-seguro-de-al-menos-32-caracteres"

# Opcional – TTL de sesión en horas (default: 8)
AUTH_SESSION_TTL_HOURS=8

# Bootstrap – para el seed de producción
MASTER_INITIAL_USERNAME=master
MASTER_INITIAL_PASSWORD=TuContraseñaSegura1!
BOOTSTRAP_BRANCH_CODE=MGA
BOOTSTRAP_BRANCH_NAME="Managua Central"
BOOTSTRAP_CREATE_CASH_BOX=true

# Para resetear contraseña master existente
RESET_MASTER_PASSWORD=false
```

hammer-frontend/.env

```
# URL del backend API
NEXT_PUBLIC_API_URL=http://localhost:4000
```

Troubleshooting

“Usuario o contraseña inválidos”

- Verificar que el username sea correcto (es case-sensitive)
- Verificar que el usuario esté activo (`isActive: true`)
- Si es la primera vez, usar la contraseña temporal proporcionada

“Demasiados intentos de inicio de sesión”

- El sistema tiene rate limiting (máx 5 intentos)

- Esperar el tiempo indicado en el mensaje
- Si es urgente, un administrador puede resetear el rate limit desde la DB

“Debes cambiar tu contraseña”

- Es normal en el primer login
- Ingresar la contraseña temporal como “Contraseña Actual”
- Crear una nueva contraseña que cumpla los requisitos

“La nueva contraseña no puede ser igual a la actual”

- Elegir una contraseña diferente a la actual

“AUTH_SESSION_SECRET_MISSING”

- Configurar la variable `AUTH_SESSION_SECRET` en el `.env` del backend
- Debe tener al menos 32 caracteres

“Base de datos no disponible”

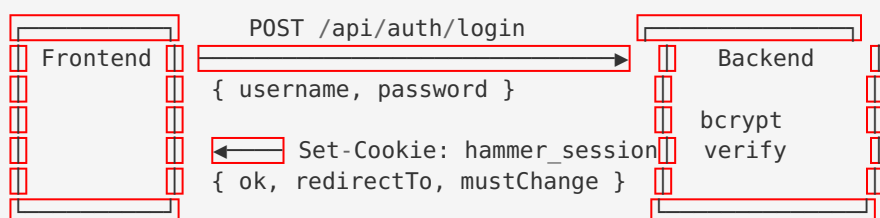
- Verificar que `DATABASE_URL` esté configurada correctamente
- Verificar que la base de datos esté accesible

El usuario no puede acceder a ninguna sección

- Verificar que tenga al menos una membresía activa (sucursal + rol)
- O que tenga un `globalRole` asignado (MASTER)



Arquitectura de Seguridad



Cookie: `hammer_session = HMAC-SHA256(payload)`

- `httpOnly`: `true`
- `secure`: `true` (producción)
- `sameSite`: `lax`
- `maxAge`: `AUTH_SESSION_TTL_HOURS * 3600`

Protección CSRF

- Todas las peticiones mutantes (POST, PUT, PATCH, DELETE) requieren token CSRF
- El token se obtiene automáticamente via `GET /api/auth/csrf`
- `apiFetch()` maneja esto transparentemente

Session Versioning

- Cada usuario tiene un `sessionVersion` counter
- Cuando se cambia contraseña, roles o se desactiva: `sessionVersion++`
- Tokens existentes con version anterior se rechazan automáticamente



Comandos Útiles

Desarrollo

```
cd hammer-api
```

```
npm run db:seed
```

```
npm run auth:reset-master
```

```
npm run dev
```

```
# Seed de desarrollo (master/ElChele1234!)
```

```
# Reset contraseña del master
```

```
# Iniciar servidor en localhost:4000
```

Producción

```
npm run db:seed:prod
```

```
npm run prisma:migrate:deploy
```

```
npm run build
```

```
# Seed de producción (requiere MASTER_INITIAL_PASSWORD)
```

```
# Aplicar migraciones
```

```
# Build de producción
```